

CHAPTER 9

Automating Internal Controls Assessment

RECENTLY, PRICEWATERHOUSECOOPERS (PwC) settled two major high-profile malpractice lawsuits in the UK. In the two cases (MF Global and Taylor Bean & Whitaker), the allegations against PwC indicated that the plaintiffs expected the audit firm to go beyond the management assertions and include management decision-making in the scope of the audit. Another firm, travel company Thomas Cook, was also audited by PwC between 2007 and 2016. Between 2017 and the collapse of Thomas Cook in 2019, Ernst & Young (EY) took over as the auditors. Upon investigation it was discovered that PwC provided remuneration advice to Thomas Cook, and that while both firms, PwC and EY, had information about the deep problems facing Thomas Cook, both gave clean audit reports to Thomas Cook. Commenting on audit failures, Bob Moritz, global chairman of PwC, said, “The expectations of the market is above the regulatory requirement. When big failures happen, it is not necessarily an audit failure. The controls might be appropriate, but the continuation of the business, its financial position and long-term sustainability can still be in question” (Kinder, [2019](#)).

- Would it be possible for PwC and EY to gain deeper insights about their clients' material weaknesses in internal controls, even before an audit is launched?
- Is it possible for PwC to develop greater insights into the business operations of a firm?
- How can management, board, and the audit committee receive continuous evaluation of audit controls?
- How can new and emerging risks be identified and mitigated?
- Can audit expand its scope without incurring greater cost?

Answers to these and many other similar questions greatly depend upon the automation strategy of internal controls. In this chapter we develop a

comprehensive strategic approach to automate internal controls assessment and audit.

AUTOMATING INTERNAL CONTROLS ASSESSMENT

Unlike the inherent risk, which is embedded in the strategic choices made by the firm due to its business model, industry, etc., the internal controls risk is a function of actions of management teams and boards. In 1993, the Committee of Sponsoring Organizations of the Treadway Commission (COSO) presented a framework, which has become the standard for internal controls. COSO defined internal control as (COSO, [2013](#)):

Internal control is a process, effected by an entity's board of directors, management and other personnel, designed to provide reasonable assurance regarding the achievement of objectives in the following three categories:

- Reliability of financial reporting.
- Effectiveness and efficiency of operations.
- Compliance with applicable laws and regulations.

The COSO standard is based upon three objectives – effectiveness and efficiency of operations, reliable financial reporting, and compliance with laws and regulations. This means that the controls exist to achieve the three objectives. The first objective of effectiveness and efficiency of operations is based upon the corporate objectives as determined by the board and the senior leadership teams and constitute the primary goals that the firm must achieve to fulfill its strategy. The second objective of reliable financial reporting is based upon the assertions made by the firm and the numbers and disclosures reported about the financial performance of the firm. The third objective aims to ensure that the firm abides by the laws and regulations applicable to its business and industry.

For each objective, internal controls are built with the following five components: (1) control environment, (2) risk assessment, (3) control activities, (4) monitoring, and (5) information and communication. Each of

the components is supported by principles and, as of 2013, 17 principles are part of the framework.

At this point it is important to note that audit automation can be viewed as a combination of tool-driven (where auditors don't rely upon any human-provided information) and human-based evidence collection. Auditees provide information in the form of data requests, access to systems and information, and responses to specific informational requests in the form of reports, questions and answers, forms, etc. Automated tools do not rely upon human-provided information and instead they directly access evidence from the source such as data, the databases, and the applications. Human-based evidence collection relies upon surveys and questionnaires. Artificial intelligence (AI) has a role to play in both areas and while this chapter primarily focuses upon the tools, the human-centric surveys and questionnaires automation involves the ability to generate and analyze surveys and questionnaires. We will cover human surveys and questionnaires in a following chapter.

Previous studies using AI methods of self-organizing maps (SOMs) based clustering techniques have suggested that internal controls form a complex nexus of capabilities where a firm may have one or more strong components (e.g., control activities and monitoring) but not all areas. Furthermore, firms may have strong components for one objective but not all three (Lämsiluoto et al., [2016](#)). Recall that there are three objectives: effectiveness and efficiency of operations, reliable financial reporting, and compliance with laws and regulations. To design an automated system, our strategy needs to cover all three COSO objectives and the related five components.

When designing an automated internal control system, our broad strategy is as follows:

- Approach the problem as an integrated interaction of various agents (both deterministic and stochastic).
- Use a variety of technologies, including process mining, machine learning, RPA, and expert systems.
- Check for internal control weaknesses that are embedded in the design of the client firm and hence create an environment ripe for errors and

frauds, and to predict if a fraudulent activity is taking place.

- Use integrated internal controls system to perform continuous assessment.
- Apply integrated internal controls system to create an exhaustive assessment (i.e., the entire population is analyzed vs. a sample).
- Evolve and grow the system with business.

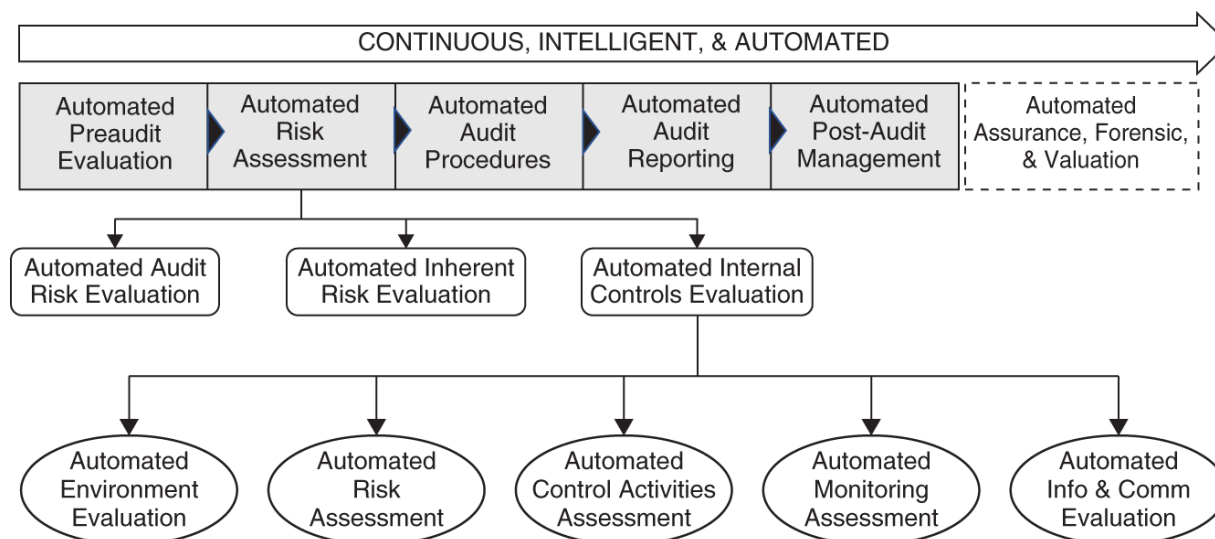


FIGURE 9.1 Automation of Internal Controls Evaluation

Automated risk assessment is composed of three areas: audit risk evaluation, inherent risk evaluation, and internal controls evaluation. Audit risk is a function of inherent risk, controls risk, and detection risk. In the previous chapter we covered the inherent risk. Inherent risk is the risk that exists in the absence of any internal controls. Internal controls risk happens when a firm does not have proper internal controls to manage and control the inherent risks. The lack of controls can be due to a firm's practices or design. It can happen intentionally or unintentionally. Internal controls can be evaded, overridden, or bypassed when management engages in fraud. Thus, while inherent risk is embedded in the nature of the business, internal controls risk is very much a product of how a firm is managed. When auditors observe gaps in internal controls, they are supposed to increase their substantive procedures to reduce or minimize the chances of misstatement.

As shown in [Figure 9.1](#), to automate the internal controls evaluation, we follow the COSO model and break it down into five capability areas of automated environment evaluation, automated risk assessment, automated control activities assessment, automated monitoring assessment, and automated information and communications evaluation. Each of the areas is automated with various agents that work in a coordinated and collaborative manner to achieve total automation.

AUTOMATED CONTROL ENVIRONMENT

The principles of control environment ([Figure 9.2](#)) are

- The organization demonstrates a commitment to integrity and ethical values.

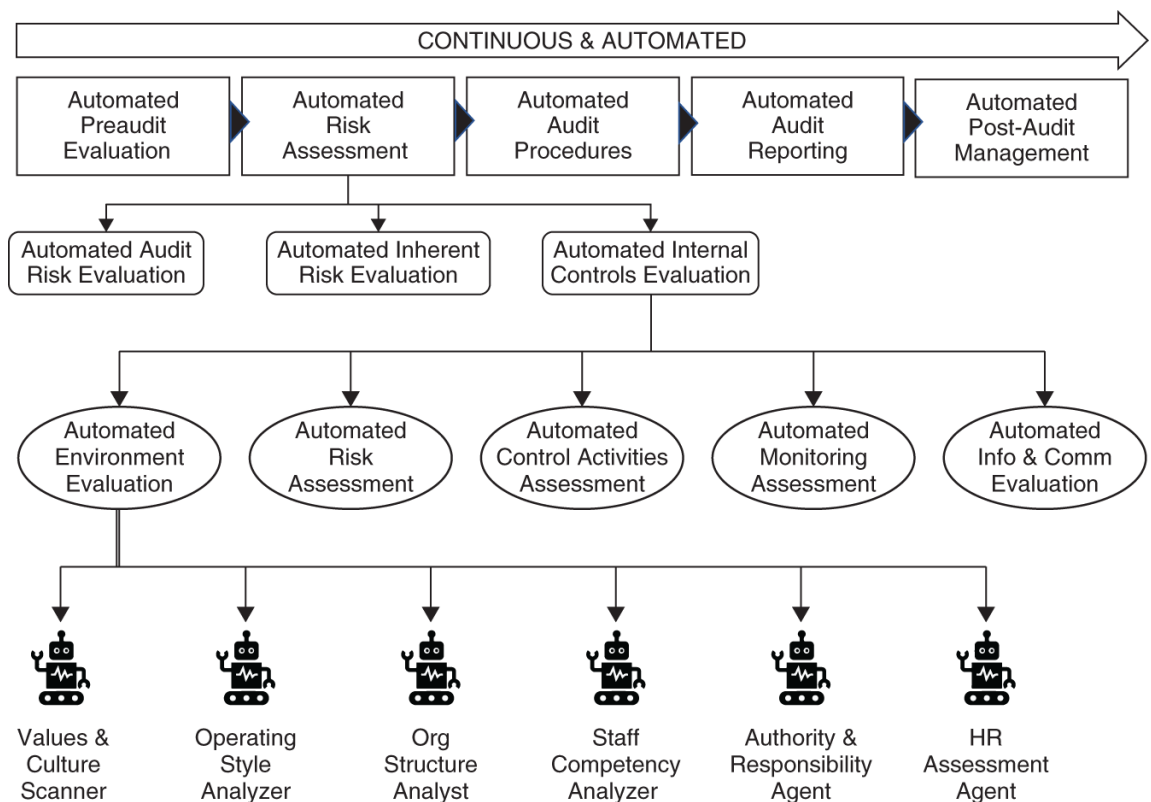


FIGURE 9.2 Automated Environment Evaluation

- The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.

- Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.
- The organization demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.
- The organization holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

The assessment of control's environment is an inquiry about the patterns of human values and actions. For example, the word “organization” in the first principle implies there are one or more humans who demonstrate commitment to integrity and ethical values. Commitment is a cognitive construct and manifests via human communications and actions. At this time, we do not have reliable technology to observe what transpires in people's minds, but we can observe patterns about humans and human behavior that can provide us information about their mental or cognitive constructs. For example, speech, choice of words, gestures, and body language (including physiological information) can give us clues about the cognitive constructs. These could be general – or specific to a domain. For example, a general assessment can reveal the personality of a person and can be classified as aggressive versus passive. A specific assessment will search for speech (verbal, written) for values.

Thus, designing a system to assess the controls environment will be composed of:

- An agent that gauges the cognitive constructs of management teams (values, ethics, personalities, integrity, and others).
- An agent that gauges the cognitive constructs of management teams and boards specific to the task structure (e.g., values or personality types to function during a specific challenge for a firm or for the specific objective of financial reporting).
- An agent that determines if the board has undertaken the responsibility of the oversight, structures, responsibilities, and authorities.
- An agent that determines that Board separation with the management team, and exercises oversight over the development and performance

of internal controls.

- An agent that measures and provides feedback on the firm's commitment to attract, develop, and retain competent individuals.
- An agent that evaluates accountability.

The above agents, once trained, form the integrated control environment system.

Integrity, Ethics, Personality, and Values

This system was explained in the audit preplanning chapter. We will reexamine it here from an internal (vs. external) system perspective. The auditor has access to significantly more documents internally than analyzing a company from the outside. In today's world, pictures, voice, and video data can also be requested and obtained. The core version of this system is natural language processing, which analyzes the written communications of the management team and the board members to search for words that signify integrity, ethics, values, and personality. As previously mentioned, this approach has been deployed to study the fraud risk from linguistic and vocal patterns of earnings calls (Throckmorton et al., [2015](#)) as well as from documents (Management's Discussion and Analysis (MD&A) section of the Form10-K) (Humpherys et al., [2011](#)). The agent is expected to evaluate how much of management and board communication is applied to values and ethics. The input documents used for these analyses may include reports, messages, board meeting minutes, emails, and other communications. Using that as input, a classification engine is deployed that, based upon words, evaluates the presence, depth, and frequency of ethics and integrity-related discussions in the normal course of business operations.

Another, more complicated, way is to get data from communications of leaders of a firm that engaged in fraud and study the patterns of their expression versus the patterns of the firms that provided proper returns and met the fiduciary obligations.

Board of Directors

The board documents and emails, including the minutes from the audit committee meetings, are analyzed to determine the presence of discussions, guidance, directives, and references to ethics, values, and integrity. The same can be done to assess the references to internal controls. This reveals the instances where the references to the internal controls were made. The email analysis also reveals the communications flow, authority, and the nature of relationship in the organization.

The features used for email can be composed of metadata of emails, number of emails, headers, text, attachment or no attachment, signed emails, forwarded, replied to, cc'd, blind copied, and other features related to frequency of emails.

Management Philosophy and Operating Style

We briefly touched upon this area in a previous chapter where our model was based upon external data. Here we use the internal data to evaluate management philosophy and operating style. Once again natural language processing can give us an excellent start to understand the management philosophy and operating style.

Management philosophy and style can be observed by the language used by the management team, the social networks within the organization, and the company culture. HR files, court documents, and websites such as Glassdoor provide excellent data for modeling. Using machine learning, your goal is to train your algorithm to classify the culture of a firm in various classes. This can be viewed as a problem of classifying the management team into various buckets of operating styles, management philosophies, and management models. For instance, you can determine if the management style is authoritarian or collaborative, closed versus open, delegation centric versus empowerment based. Employee behavior in organizations can be predicted by deploying machine learning and data mining textual information such as emails (Straub et al., [2016](#)).

Organizational Structure

The organizational structure assessment comes from multiple angles. The analytical capability is systematically built by layering the following

capabilities:

- The analyzer for organizational structure: this utility looks at the organizational job descriptions and classifies employees into internal controls specific roles. The data mined are the job descriptions, departments names, people, titles, etc. A separate analysis of organization can also show power flows, influence, and informal social links (Fire and Puzis, [2016](#))
- The analyzer also looks at the chart versus actual authority structure. The chart authority structure is as represented in the organizational charts and subject to the reporting relationships. The actual authority structure is determined based upon analyzing the social networks from emails, texts, and other information. The social hierarchy can be determined from machine learning by analyzing the emails (Rowe et al., [2007](#)).

Financial Reporting Competencies

The financial reporting competencies can be obtained by understating the educational background, experience, and type of education.

The training data set for competency includes the typical HR data, as well as data from resumes, LinkedIn, and other social media data. It also includes data from the number of publications by the person, involvement in various professional societies, trainings, and certifications.

This artifact can be designed two ways. The first approach is to use HR data from a larger data set (which might include data from multiple companies) and have a human apply labels to the data. The label in this case will be applied to learn the competence levels for a position. Factors such as years on the job, educational background, experience, etc., will be the input data set. Valuable information can be extracted from resumes (Reza and Zaman, [2017](#)). The 'y' or output variable will be competent versus incompetent for a given job.

The second and more interesting artifact uses the data set of input variables including experience, years on the job, educational background from an actual data set of frauds and failure in that position. While interesting, it

will be hard to reconstruct a data set for training purposes since it will be hard to pinpoint the blame for a failure.

Authority and Responsibility

Authority and responsibility are assessed by using various intelligent automation technologies. We are trying to assess whether management assigned the responsibility of internal controls appropriately and the employees were given the appropriate controls and authority to ensure that internal controls are in place and effective. There are several ways to assess that from the machine learning perspective.

The first is to have an agent that uses the human resources data to understand the job responsibilities. The data collection can also extend to the annual employee review and evaluation forms that typically contain more detailed accounts of actual work undertaken by employees. In addition, emails and communications can also be used as the data input. The model uses natural language processing to evaluate if, given the role of the individual, his or her responsibility structure includes references to position-specific internal controls. Notice that in this assessment, we are only evaluating the environment and not the activities. Therefore, our focus remains on studying the environment of the organization.

While responsibility is assessed using the above, analyzing authority is a whole different ballgame. Authority manifests in enabling a manager or employee to conduct themselves in the proper manner, not enforcing improper or unnecessary constraints, assuring employees that there will be no negative consequences when employees file a complaint or become a whistleblower.

Authority is a function of being able to act upon what a person has been made responsible for. In corporate systems, access is provided to individuals by a workflow that records the person who authorized the access. Logs from that system can show if the authorization is being done at the right level and being done by the person who has the authority to do it, or by someone higher up in the organization, or by more than one person. The culture can provide an indirect proxy for authority assessment. More authoritative leaders will be less inclined to allow people to function independently, even when it comes to such an important role as internal

controls. Finally, internal emails, meeting notes, and communications provide excellent data for assessing the level of authority key employees have. In advanced settings both video and speech can be used to study the cultural dynamics of a firm. To accomplish that level of automation, process mining and machine learning are used, and their applications are explained later in this chapter.

Human Resource Policies and Practices

Large data sets are available and can be mined in human resources (Jia et al., [2018](#)). The objective of control environment assessment with respect to HR is to determine whether the department is aware of the underlying concepts of separation of duties, internal controls, and hiring the right talent to mitigate the risks. The policies and practices of HR can be analyzed using natural language processing and the usage of key terms (separation of duties, etc.) can be assessed to develop insights into HR capabilities. Similar concepts, as discussed above, are applied to determine the capability and contribution of the HR department in supporting stronger internal controls.

AUTOMATED RISK ASSESSMENT

Automated risk assessment was extensively covered in the previous chapter from an inherent risk perspective. We recognized that there are at least four automated methods to explore risk in an organization. The first method focused on the account- and assertion-specific risk identification and management. The three remaining methods, shadow/parallel accounting, strategic objectives, and deep learning, can be used for any type of risk management capability development. In fact, in our case, COSO framework requires management to understand risks from the perspective of achieving company's objectives. The COSO [2013](#) framework outlines the four principles of risk assessment:

1. The organization specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.
2. The organization identifies risks to the achievement of its objectives across the entity and analyzes the risks as a basis for determining how

the risks should be managed.

3. The organization considers the potential for fraud in assessing risks to the achievement of objectives.
4. The organization identifies and assesses changes that could significantly impact the system of internal control.

In this chapter we will expand on the model presented in inherent risk evaluation and include risk assessment from an internal control perspective, and also introduce the concept of event-based risk assessment.

The process is composed of four levels of automation:

Level 1: Outside-in – Get a general idea about potential material weakness in internal controls (MWIC) by using publicly available information. This gives auditors a sense of how risky a client situation might turn out to be.

Level 2: Process centric – Understand the risk relationship between processes and controls.

Level 3: Enterprise – Develop greater insights into the value chain and business processes of the organization. This is similar to enterprise-based risk analysis frameworks.

Level 4: Business decisions – Auditors do not consider this to be part of their jobs; however, as the opening case study of PwC settling two lawsuits shows, there is a growing movement to place that responsibility on auditors. The reasoning behind that is clear. The economic consequences of management decisions and objectives flow through the financial systems and the stakeholders expect auditors to understand and evaluate such realities of business. The consequences of management business decisions can also become the motivation factors to conduct fraud. In other cases, management decisions impact the future cash flows and the cost of capital of a firm and therefore impact the valuation of many current assets.

Level 1: Outside-In Analysis

A group of researchers wanted to explore if it is possible to identify material weaknesses in internal controls from using publicly available external data (Simsek et al., [2018](#)). Looking at various companies that announced material weakness in internal controls, the group identified financial data from historical financial statements one year prior to the disclosure. Using that data – data that included financial ratios such as total asset turnover, profitability, capital intensity, size, current ratio, and operating performance – the research team tried to predict the internal control weaknesses. After applying various methods, the team was able to obtain 70 to 80% accuracy in results. This means that the team was able to predict, with reasonable accuracy, that material weakness exists in internal controls only by using the historical financial data. A similar artifact can be deployed to identify such weaknesses in companies.

In fact, given today's technology advances, the predictive power of such an artifact can be significantly enhanced by adding features and using a deep learning environment.

Level 2: Process Centric

As we move beyond our Level 1 analysis, we can go a level deeper to determine if the primary processes in a firm carry greater risk. This evaluation is a function of feature data obtained from historical records of internal control problems. For instance, a data set that contains the examples of prior misstatements or disclosures of internal control weaknesses can be used to identify the presence of MWIC by industries, companies, and process types. At least two types of machine learning methods can be deployed to develop insights into process-centric MWIC.

The first approach is similar to the one by Simsek et al., discussed in the previous section, except that instead of using financial and operational performance data as feature inputs, we use industries, company types, business model descriptions, and processes to understand the likelihood of MWIC.

The second approach borrows from methods developed in studying human errors in accidents. The study of human errors in accidents has significant literature. In 1998, Hollnagel authored a book titled *Cognitive Reliability*

and Error Analysis Method (Hollnagel, [1998](#)). In that book he developed three taxonomies. The first was the taxonomy of technology, in which he pointed out the problems that can afflict machines (e.g., equipment failure, procedure failure, interface failure). The second taxonomy was of “man,” implying the cognitive problems that can afflict a human (e.g., planning, execution, memory, interpretation, observation). The third taxonomy was of the organization, including the failure points in an organization (e.g., training, working conditions). Hollnagel presented a Cognitive Reliability and Error Analysis Method (CREAM), which shifted the focus from the task characteristics and on a hypothetical inherent human error probability, to the principle that context is the driving force behind Human Reliability (R. Moura et al., [2015](#)). Moura, Beer, Patelli, Lewis, and Knoll identified the importance of the principle and expanded upon that to use a major accidents data set, applying a clustering technique (unsupervised) to classify the data to discover various causes of accidents. They used self-organizing maps (SOMs) to cluster and classify data (Moura et al., [2015](#); Moura et al., [2017](#)). The SOM technique also enables multidimensional data to be viewed in a two-dimensional representation (Kohonen, [2013](#)). Similar to what Moura, Beer, Patelli, Lewis, and Knoll ([2015](#)) did, SOM/Clustering can be applied to understand the drivers of MWIC.

Level 3: Value Chain and Enterprise Risk Relationships

We covered a risk management process in [Chapter 7](#). By understanding the value chain relationships and enterprise-centric risk, we develop insights into potential problems that may arise in situations where external parties are involved (e.g., sales and procurement). Developing those insights helps give auditors an idea about potential deterioration in value of assets (e.g., knowledge about a major customer going bankrupt will impact the AR held by the client firm).

The enterprise risk management process is composed of the following processes: identify risks, develop assessment criteria, assess risks, assess risk interactions, prioritize risks, and respond to risks (Curtis and Carey, [2012](#)). The use of AI in the risk management process automates the process flow of risk management.

Level 4: Business Decisions Analysis

This area of risk analysis is critical to improve audit quality and to help develop a deeper, more insightful perspective for auditors. The automation in this case follows the standard approach of understanding the enterprise risk. There are established methods and approaches for identifying, measuring, and managing enterprise risks.

Technology Design

Before presenting the methodology to accomplish that goal, it is important to understand the two types of data critical for performing the control activity analysis. The first is the transactional data. This is the regular data we use to perform analysis and includes data from databases such as sales, accounting, and procurement. The second type of data, known as metadata, is the data about the data – for example, computer's log data about transactions. Metadata captures things like who accessed the system, when an entry was made, or what changes took place.

Control activities review is based upon three types of analysis: data-centric and metadata-centric and data + metadata-centric. To appreciate the power of automation, it is important to recognize that automated evaluation of control activities ties directly to the risk review done in the previous section, as well as actual audit procedures. Even though we presented the total audit automation model as a linear model, a machine, unlike humans, doesn't need the process transition nodes and can instead perform all processes simultaneously.

Metadata-Centric Analysis

Process-specific analysis is a growing area of audit automation. The advent of process-mining technology was a transformational step for conducting risk evaluation using event log data. Analytical methods are applied to extract insights from the log data to understand audit-related patterns. The data extracted from event logs includes information about which system was accessed, when, and by whom. This is known as the activity, routing, and resource information. Process mining is rules-based extraction of data. This information is used to capture the audit evidence to determine factors such as

- Was the system accessed by the people who are authorized to do so?
- Was the system accessed at odd times or near the closing period?
- Was the system accessed with higher frequency at some time intervals?
- Were two or more systems being accessed by a person whose responsibilities do not allow him or her to do so due to separation of duties?
- Were systems accessed by a group of people whose hours of accessing the system matched, however, they typically don't access systems at the same time?

In their impressive work, Jans et al. ([2013](#)) made a strong case for using process mining in audit and argued the value creation potential of using process mining. They presented the following four key attributes of process mining:

1. Process mining analyzes the entire population of data and not just a sample.
2. Critically that data consists of meta-data – data entered independently of the actions of auditee – and not just data entered by the auditee.
3. Process mining allows the auditor to have a more effective way of implementing the audit risk model by providing effective ways of conducting the required walk throughs of processes and conducting analytic procedures.
4. Process mining allows the auditor to conduct analyses not possible with existing audit tools, such as discovering the ways in which business processes are actually being carried out in practice, and to identify social relationships between individuals.

Process mining can be used to identify processes from beginning to end – giving a comprehensive view of how a process moves through the company's systems and laying out the audit trail. Van der Aalst et al. ([2010](#)) outline the capabilities of process mining as being able to provide business provenance by ensuring traceability, process discovery by identifying

frequent patterns, and being able to compare an a priori model with the event logs and vice versa.

Data-Centric Analysis

Data-centric internal control analysis refers to analyzing the transactional data to assess internal controls and to performing actual substantive procedures and testing. This data includes that which resides in accounting systems and that becomes the source of information used to construct the financial statements supplied by the management. These are the general analysis, such as budgets, reports, business intelligence, business analytics, and other management information reporting. In human-led control structures, these reports are the life-blood of decision-making.

In an automated world, some of that decision-making will no longer be performed by humans. Much of this will be discussed in the next chapter. However, for this chapter it is important to consider that a computerized financial system is made up of transactional data, the underlying processes and structures, and the human who enters data or makes decisions outside of the system. These decisions could be about how to treat a transaction, or what/how to reconcile, or how to record an entry. But while the human decision-making can be considered as outside the system, since it happens in the human mind, those decisions impact what transpires in the computerized financial system. We, the humans, are both part of the system and exist outside of it. As we move ahead with the AI revolution, we may need to think differently about viewing what goes on in the human mind as external to the system and instead include those thoughts, decisions, and cognitive frameworks as part of the system. This broadening of the system concept happens as cognitive frameworks and decision-making is transferred from human mind and embedded in the financial system.

Data + Metadata

The addition of machine learning to process mining is a great innovation for audit. When combined, both can produce continuous, automated, and integrated audit. Six years after proposing the use of process mining, Jans, with another author, proposed the use of machine learning with process mining (Jans and Hosseinpour, [2019](#)). The idea of machine learning comes from the fact the process mining creates an extremely large number of

exceptions. These exceptions are then interpreted by humans and marked as “of interest” and “not of interest.” The exceptions provide a huge source of learning data, such that the machine can learn how to classify the output of process mining data. In fact, human-classified data provides a perfect set of examples needed to teach machines how to identify good versus unacceptable patterns. Using the classification algorithms, the machine can identify patterns and generalize its learning to recognize previously unknown anomalous patterns.

CONTROL ACTIVITIES

Unlike the control environment assessment, which focused on the passive factors of internal controls, control activities focus on actions and activities related to ensuring that internal controls are implemented, and that board and management directives are followed about internal controls. The goal of evaluation of control activities (McNally, [2013](#)) is to ensure that the organization

- Selects and develops control activities
- Selects and develops general controls over technology
- Deploys policies and procedures

The goal of intelligent automation is to automate the evaluation of the achievement of the above three goals automatically.

Selects and Develops Control Activities

The selection and development of control activities is a function of the risks identified. Every significant risk requires controls so that the overall goal of ensuring that risk of material misstatement for all relevant assertions is effectively managed. In some ways, controls serve the preventative role. Frauds and errors should be detected and corrected before they enter the financial system.

The selection and development of controls can be viewed as establishing a link between each significant risk and the preventative process designed to block fraud and error entering the financial system. This preventative

process is composed of activities that are embedded in the workflows and business processes. For example, hiring the right people, establishing separation of duties, developing limits on transaction sizes, implementing approvals in the workflow, and limiting access to systems are some of the key activities undertaken.

In the context of modernization of audit, there are two ways to determine whether management is actively selecting and developing controls and therefore actively engaging in control activities.

- The first is the direct evidence obtained in response to the known risks evaluation. This evidence is not based upon questionnaires but is acquired directly (as discussed in the previous section) and it shows whether the management has done a good job in preparing the organization to prevent material errors and fraud finding their way into the accounting systems.
- The second is to understand the management's ability and preparation for unknown or unanticipated emergent risks that can arise rapidly and lead to a material event. Since the auditor's focus is primarily on the historical information, one can question the need for including this in the assessment. The reason for that is simple. Even if we ignore the direct benefits for assessing the potential versus known risk-centric evaluation, the fact that management is engaging in understanding potential risks is on its own an indication of management being responsible and active in preventative response.

The model implies establishing a context-sensitive model that offers a relationship between risks and preventative response processes. In many cases there will be similarities between various approaches and risks. An assertion risk may call for a specific functional separation of duties – for instance, in accounts payable, purchasing, and receiving – regardless of the company. In other cases, risks may require new, customized, or creative preventative responses. Most auditing operates with existing models, what van der Aalst et al. calls *de jure* models that “describe a desired or required way of working,” in contrast to *de facto* models that “aim to describe reality with potential violations of the boundaries defined in *de jure* models” (van der Aalst et al., [2011](#), [2010](#)). Hence, we can assume that the *de jure* model

results from the knowledge of what works and what doesn't work. In this case, they come from auditor's knowledge of a certain preventative control being an effective mitigation to a certain specific risk. This implies that an ontology of risks and preventative measures can be created, which essentially can be transformed into a set of rules that can be invoked or checked against for an audit.

The machine learning – centric automation for control activities automation refers to two applications:

1. The application that studies new risk patterns and suggests mitigation strategies. This can be a combination of both unsupervised (clustering) and supervised (classification) approaches. The job of this application is to update the existing de jure models. Whether that update happens via learning or updating existing rules, risk-response patterns recognition is the core capability needed to propose and develop effective control activities in response to emerging risk patterns.
2. The application that incorporates the above learning and compares it to de facto situations. This is done from a combination of “metadata + data” analysis, as discussed in the previous section. Van der Aalst et al. clarified that concept when they said, “It is possible to promote a de facto model to a de jure one. A comparison showing that the actual process execution is inconsistent with the standard preexisting model may motivate an update of the de jure model” (van der Aalst et al., [2010](#)). What machine learning does is to explore the inconsistency between the de jure model and the de facto model and then if it finds the de facto model more effective, it updates the de jure model. The learning can happen from at least three sources: (1) historical data from previous audits; (2) auditor (human)-provided knowledge base where the auditor provides examples of an effective response; and (3) the system is designed with a critic that can simulate the risk scenarios and critique the strategies used to prevent and counter the risks in terms of a goal structure. This design will generally require the use of reinforcement learning.

Selects and Develops Controls Over Technology

Control activities related to technology were addressed by van der Aalst et al. ([2011](#)) in which they proposed the concept of an oversight system being created to monitor another system. They clarified that a control is “an automated task in the information system aimed at the prevention of violations of certain business rules. These controls are strongly related to the functions of the information system” and then cautioned that “often business rules are generic (i.e., not bound to a specific business context).” The process of management deploying controls over information technology is being achieved by continuous controls monitoring (CCM). CCM is a collection of tools that extract data from databases and scans for separation of duties, authorizations, breaches, errors, anomalies, size limits of transactions, etc. These controls are embedded within the technology.

Technology access controls are also important considerations. Separation of duties can be ascertained from the reports about who logged into systems. Ensuring that only those people who are authorized to access the systems do so is essential for establishing a better controls environment.

The advent of AI will have three important impacts on this area. First, two types of analysis – predictive and prescriptive – are added to the deterministic, rule-based anomaly detection of CCM. This means that the system not only analyzes data from databases, it uses the data to learn about breaches and hence predicts them and offers prescriptive remedies to counter the threats. The second impact is that significantly larger amounts of data can be processed and deployed in deep learning – centric architecture. This enables detecting frauds and errors that are not easily detectable. Third, AI's introduction will lead to control redesign and weakening of existing controls. Intelligent systems are deployed not only by those who are trying to protect a firm, but also by those who don't mean well. This means that intelligent controls will be needed.

Consider the fact that our transactional (deterministic) systems have a source of concern for us from a controls perspective – imagine the arrival of intelligent machines in our organization. How will we manage and control them? The advent of AI will further exacerbate the problem of controls. This topic is covered in [Chapter 18](#) of this book.

Deploys Policies and Procedures

The policies and procedures are scanned and using natural language processing analyzed to determine if they comply with the risk types identified for the client firm. For instance, frequency of key words can classify documents into various areas of controls and determine if there was proper coverage of each area of controls. For instance, using the Term Frequency – Inverse Document Frequency (TF-IDF) method, documents can be analyzed and classified based upon importance and coverage.

example: What Is TF-IDF? Term Frequency – Inverse Document Frequency

TF-IDF is a natural language processing method that is based upon calculating the frequency of words. It has two parts, the TF part and the IDF part. In the TF part, the algorithm calculates the number of times a term is used in a document. For example, if you are analyzing a document pertaining to policies and procedures, you can learn that the words “Separation” and “Duties” were used 34 and 28 times respectively. If the document is a total of 1000 words long, the word frequency will be calculated as 34 divided by 1000 for Separation and 28 divided by 1000 for Duties. This gives an estimate of how many times each term was used in a document and can provide a sense of importance of that term in a document. In the IDF part, we calculate the inverse document frequency by taking the whole corpus (all documents) and identifying how many documents used the term overall. It is calculated by taking a base 2 log of the number of documents divided by the number of documents in which the term was used. Let us say that there are 50 documents that make up the policy and procedures and the terms “Separation” and “Duties” appear in 12 and 32 documents, then $\log_2(50/12)$ and $\log_2(50/32)$ respectively will give us the inverse document frequency. The TF-IDF is then calculated by multiplying TF by IDF. By using this method, we can determine the relevance of documents to various topics. Once TF-IDF values are determined, we can also calculate the similarities among documents. For example, we can estimate which documents focus on Separation of Duties – related internal controls.

Physical Controls and Machine-Generated Data

Physical controls are necessary to protect certain types of assets. In the past, the controls for physical access were limited to installing cameras and locks. With the advances in AI we now have the opportunity to make significant improvements in the physical controls. The opportunities exist in automated evaluation of video input to assess whether that usage of the

asset is in accordance with the expected use. The video feed can be analyzed for misuse, theft, and intentional asset destruction. In addition to video, other Internet of Things (IoT) data can be analyzed to determine controls over production, inventory, warehouses, etc. Similarly, data from trucks can be analyzed regarding travel miles, maintenance, and fleet usage patterns.

AUTOMATED MONITORING

Monitoring refers to the management monitoring the internal control activities on an ongoing basis. The standards require the management team to

- Conduct ongoing and/or separate evaluations.
- Evaluate and communicate deficiencies: The goal of evaluation is to ensure that management actively leads, manages, and participates in reporting. In an automated system, the function of automated monitoring is embedded within the machines. In the initial stages of automation, it is expected that humans and machines will share the monitoring responsibility but as technology moves forward, the responsibility will shift to the machines.
- Automated controls providing information about machines: The auditors would want to see evidence that automated controls are providing evidence about monitoring activities.
- Risk simulation: Auditors should be able to simulate risk in an environment and observe the performance of controls.
- Critic: Determine if a critic exists that automatically critiques the performance of the monitoring controls.
- Business process gap analysis: Automated checks are performed for business process gap analysis.
- Budgets, variance, and scorecards.

INFORMATION AND COMMUNICATIONS

The guiding principles of COSO about information and communications emphasize that an organization must

- Obtain or generate and use relevant quality information to support the functioning of internal controls.
- Internally communicate information, including objectives and responsibilities for internal controls, necessary to support internal controls.
- Communicate with external parties regarding internal controls.

The goal of the automated internal control information and communications systems is to constantly collect and compile actionable information about internal controls and then disseminate it to both internal and external parties.

The previous sections addressed several artifacts that can be deployed to automate internal controls. These artifacts will provide information about their own state as well as about their activities. For instance, self-governance can be built into the artifact and can report on factors such as

- Business process
- Transaction details
- Other events
- Data lineage

Reports generated from these can be sent to all relevant parties and an escalation workflow can be designed.

CONTROL RISK AND NEXT STEPS

Our audit planning began with using extensive information about the firm from external sources to develop a good analysis for risk. In some cases, the external (outside-in) analysis will expose the risk areas as clearly as a flashlight exposing a point of interest in a dark room. In other cases, they

will develop our instincts and make us more aware of what lies ahead in an engagement.

From outside-in we moved to the internal data and systems of a firm. Our approach became more invasive and deeper. We penetrated the shields of obscurity and gained direct access to data. It was from that point where we began gaining confidence in our ability to monitor and assess controls intelligently and constantly.

With a good understanding of inherent risks and control risks, auditors can assess the focus and extent of substantive procedures. We discuss direct evidence collection from accounts and substantive procedures in the next chapter.

Key Points

- Internal controls testing is one of the most important objectives of an audit. While inherent risk is usually unmanageable and is a function of a company's business model among other things, control risk can and should be managed.
- Control risk is composed of five types of automations including automated controls environment, automated risk assessment, automated control activities assessment, automated monitoring assessment, and automation information and communications evaluation.
- An audit automation plan must address all of these areas.

REFERENCES

COSO (2013) *Internal Control – Integrated Framework*. [online]. Available from: <https://www.coso.org/Documents/990025P-Executive-Summary-final-may20.pdf>.

Curtis, P. and Carey, M. (2012) Risk assessment in practice. COSO. [coso.org](https://www.coso.org).

- Fire, M. and Puzis, R. (2016) Organization mining using online social networks. *Networks and Spatial Economics*, 16 (2): 545–578.
- Hollnagel, E. (1998) *Cognitive Reliability and Error Analysis Method*. Oxford: Elsevier Science.
- Humpherys, S. L., Moffitt, K. C., Burns, M. B., Burgoon, J. K., and Felix, W. F. (2011) Identification of fraudulent financial statements using linguistic credibility analysis. *Decision Support Systems*, 50 (3): 585–594.
- Jans, M., Alles, M., and Vasarhelyi, M. (2013) The case for process mining in auditing: Sources of value added and areas of application. *International Journal of Accounting Information Systems*, 14 (1): 1–20. Available from: <http://dx.doi.org/10.1016/j.accinf.2012.06.015>.
- Jans, M. and Hosseinpour, M. (2019) How active learning and process mining can act as Continuous Auditing catalyst. *International Journal of Accounting Information Systems*, 32 (November 2018): 44–58. Available from: <https://doi.org/10.1016/j.accinf.2018.11.002>.
- Jia, Q., Guo, Y., Li, R., Li, Y., and Chen, Y. (2018) A conceptual artificial intelligence application framework in human resource management. *Proceedings of the International Conference on Electronic Business (ICEB)*, December, 106–114.
- Kinder, T. (2019) Thomas Cook collapse will intensify UK audit debate, PwC says. *Financial Times*.
- Kohonen, T. (2013) Essentials of the self-organizing map. *Neural Networks*, 37: 52–65. Available from: <http://dx.doi.org/10.1016/j.neunet.2012.09.018>.
- Lämsiluoto, A., Jokipii, A., and Eklund, T. (2016) Internal control effectiveness – a clustering approach. *Managerial Auditing Journal*, 31 (1): 5–34.
- McNally, J. S. (2013) The 2013 COSO Framework & SOX Compliance: One approach to an effective transition. *Strategic Finance*. June (The Committee of Sponsoring Organizations of the Treadway Commission

(COSO)). Available from: [https://www.coso.org/documents/COSO McNallyTransition Article-Final COSO Version Proof_5-31-13.pdf](https://www.coso.org/documents/COSO_McNallyTransition Article-Final COSO Version Proof_5-31-13.pdf).

Moura, Raphael, Beer, M., Lewis, J., and Patelli, E. (2015) Learning from accidents: Analysis and representation of human errors in multi-attribute events. *12th International Conference on Applications of Statistics and Probability in Civil Engineering, ICASP 2015* (July).

Moura, R., Beer, M., Patelli, E., Lewis, J., and Knoll, F. (2015) Human error analysis: Review of past accidents and implications for improving robustness of system design. *Safety and Reliability: Methodology and Applications - Proceedings of the European Safety and Reliability Conference, ESREL 2014*. [Online] (September), 1037–1046.

Moura, R., Beer, M., Patelli, E., Lewis, J., and Knoll, F. (2017) Learning from accidents: Interactions between human factors, technology and organisations as a central element to validate risk studies. *Safety Science*, 99: 196–214. Available from: <http://dx.doi.org/10.1016/j.ssci.2017.05.001>.

Reza, T. and Zaman, S. (2017) *Analyzing CV/resume using natural language processing and machine learning*. BRAC University. Available from: http://dspace.bracu.ac.bd/xmlui/bitstream/handle/10361/9480/14101061%2C14101171_CSE.pdf?sequence=1&isAllowed=y.

Rowe, R., Creamer, G., Hershkop, S., and Stolfo, S. J. (2007) Automated social hierarchy detection through email network analysis. *Joint Ninth WebKDD and First SNA-KDD 2007 Workshop on Web Mining and Social Network Analysis*. [Online] 109–117.

Simsek, S., Bayraktar, E., Raghothaman, S., and Dag, A. (2018) A Bayesian approach to detect the firms with material weakness in internal control. *IISE Annual Conference and Expo 2018*. 971–976.

Straub, K. M., (2016) *Data mining academic emails to model employee behaviors and analyze organizational structure*. Available from: https://vtechworks.lib.vt.edu/bitstream/handle/10919/71320/Straub_KM_T_2016.pdf;sequence=1.

Throckmorton, C. S., Mayew, W. J., Venkatachalam, M., and Collins, L. M. (2015) Financial fraud detection using vocal, linguistic and financial cues. *Decision Support Systems*, 74: 78–87. Available from: <http://dx.doi.org/10.1016/j.dss.2015.04.006>.

van der Aalst, W. M. P., Van Hee, K. M., Van Der Werf, J. M., and Verdonk, M. (2010) Auditing 2.0: Using process mining to support tomorrow's auditor. *Computer*, 43 (3): 90–93.

van der Aalst, W., Van Hee, K., Van Der Werf, J. M., Kumar, A., and Verdonk, M. (2011) Conceptual model for online auditing. *Decision Support Systems*, 50 (3): 636–647. Available from: <http://dx.doi.org/10.1016/j.dss.2010.08.014>.

OceanofPDF.com